

CUADERNILLO DE ESTUDIO

CLASE 6

*“Gestión de riesgos II:
BIA, controles e ISO 27001”*

▲ Incluye preparación para el PARCIAL 1

Profesor: Mg. Ing. Rodrigo Atilio Elgueta

Unidad: Cierre de Unidad 2

Datos del/la estudiante

Nombre y apellido: _____

Grupo N.º: _____

Negocio Digital (TP): _____

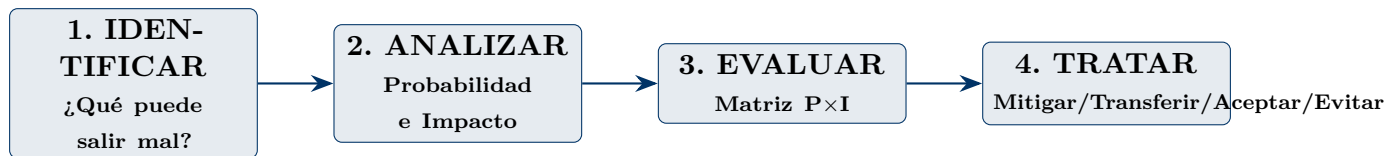
Fecha: _____

Índice

1. Repaso express: lo que traemos de la Clase 5	2
2. BIA: Análisis de Impacto al Negocio	3
2.1. ¿Para qué sirve?	3
2.2. Los tres conceptos fundamentales del BIA	3
2.3. Plantilla de BIA simplificado	3
3. Tipos de controles y costo-beneficio	5
3.1. Las 4 categorías de controles	5
3.2. Además: ¿previenen, detectan o corrigen?	5
3.3. Criterio costo-beneficio	5
4. Introducción a ISO/IEC 27001 y 27002	7
4.1. ¿Qué es cada una?	7
4.2. ¿Por qué le importa a un negocio digital?	7
5. Cierre de Unidad 2: mapa integrador	8
6. PARCIAL 1: formato, rúbrica y recomendaciones	9
6.1. ¿Qué deben entregar?	9
6.2. Rúbrica de evaluación (sobre 10 puntos)	9
6.3. Las preguntas cruzadas individuales	9
7. Simulacro de Parcial: caso de práctica	11
8. Glosario de la Clase 6	13
9. Espacio para notas y dudas	13

1. Repaso express: lo que traemos de la Clase 5

Antes de avanzar, aseguremos los cimientos. En la Clase 5 vimos el **ciclo de gestión de riesgos**:



Hoy profundizamos en dos piezas clave de ese ciclo:

- El **análisis de impacto** (BIA), que le pone números al daño.
- Los **controles**, que son las herramientas concretas para **tratar** los riesgos.

Pregunta disparadora

Si el servidor de facturación de tu negocio se cae 4 horas un sábado a la noche, ¿cuánto dinero perdés? ¿Y si se cae un martes a las 11 de la mañana? **No todos los procesos valen lo mismo, ni todas las caídas duelen igual.** Eso es lo que mide el BIA.

2. BIA: Análisis de Impacto al Negocio

Definición

El **Business Impact Analysis (BIA)** es el proceso de identificar los procesos críticos del negocio y cuantificar el impacto que tendría su interrupción, con el objetivo de definir prioridades de recuperación y continuidad.

2.1 ¿Para qué sirve?

- **Priorizar:** no todo se recupera al mismo tiempo; primero lo crítico.
- **Dimensionar inversiones:** justificar cuánto gastar en backup, redundancia o contingencia.
- **Definir objetivos de recuperación:** cuánto tiempo podemos tolerar sin cada proceso.

2.2 Los tres conceptos fundamentales del BIA

Sigla	¿Qué pregunta?	Ejemplo
MTD	¿Cuánto tiempo máximo puede estar caído este proceso antes de que el daño sea inaceptable?	“La pasarela de pago no puede estar caída más de 2 horas.”
RTO	¿En cuánto tiempo nos proponemos recuperarlo tras un incidente?	“Objetivo: volver a operar en 1 hora.”
RPO	¿Cuántos datos podemos permitirnos perder? (cada cuánto hago backup)	“Backup cada 15 min → pierdo máx. 15 min de datos.”

Regla práctica: Siempre debe cumplirse que $RTO \leq MTD$. Si tu proceso tolera máximo 2 horas caído (MTD) pero tu plan de recuperación tarda 6 horas (RTO), tenés un problema de diseño. El RPO, además, define la frecuencia mínima de tus backups.

2.3 Plantilla de BIA simplificado

Esta es la tabla que van a usar en el Parcial 1. Completala para cada proceso crítico:

Proceso / Activo: _____

Impacto por hora de caída: (Económico / Legal / Reputacional / Operativo)

MTD (Máx. tiempo tolerable): _____

RTO (Objetivo de recuperación): _____

RPO (Pérdida máx. de datos aceptable): _____

Prioridad (Crítico / Alto / Medio / Bajo): _____

Proceso: Pasarela de pago (checkout).

Impacto por hora de caída: Económico alto (se pierden ventas directas) + reputacional (clientes frustrados en redes).

MTD: 2 horas (en temporada alta, 30 minutos).

RTO: 1 hora.

RPO: 5 minutos (las transacciones no se pueden perder).

Prioridad: CRÍTICO.

3. Tipos de controles y costo-beneficio

Un **control** es cualquier medida (técnica, humana, física u organizativa) diseñada para reducir la probabilidad o el impacto de un riesgo.

3.1 Las 4 categorías de controles

Categoría	¿Qué abarca?	Ejemplos
Técnicos	Soluciones tecnológicas que previenen, detectan o corrigen.	Firewall, MFA, cifrado, antivirus, backups automáticos, IDS/IPS.
Humanos / Organizativos	Acciones sobre las personas y los procesos.	Capacitación, concientización, políticas, roles, procedimientos.
Físicos	Protección del espacio y el hardware.	Cámaras, control de acceso al data center, cerco perimetral, UPS.
Legales / Normativos	Cumplimiento de leyes y contratos.	Política de privacidad, NDAs, seguros, cláusulas con proveedores.

3.2 Además: ¿previenen, detectan o corrigen?

Cada control puede clasificarse según su **función en el tiempo**:

- **Preventivo:** evita que el incidente ocurra (ej. MFA, capacitación).
- **Detectivo:** alerta cuando el incidente está ocurriendo (ej. antivirus, cámaras, monitoreo).
- **Correctivo:** restaura la normalidad después del incidente (ej. backups, plan de respuesta).

3.3 Criterio costo-beneficio

La pregunta de negocio

Un control solo se implementa si **el costo del control es menor que el impacto esperado del riesgo**.

Fórmula conceptual:

$$\text{Beneficio del control} \approx (\text{Impacto del riesgo}) - (\text{Costo del control})$$

Si proteger un activo cuesta más que el activo mismo, la decisión correcta suele ser **aceptar** o **transferir** el riesgo, no mitigarlo.

Riesgo: Filtración de base de datos de 10.000 clientes por un bucket mal configurado.

Impacto estimado: Multa + pérdida de clientes $\approx$ \$500.000.

Control propuesto: Revisión de configuraciones cloud + cifrado. Costo: \$30.000/año.

¿Lo implementás? Justificá en 2-3 líneas:

4. Introducción a ISO/IEC 27001 y 27002

Cuando una organización quiere ordenar toda su seguridad de forma sistemática, recurre a estándares internacionales. Los dos más importantes son la familia ISO/IEC 27000.

4.1 ¿Qué es cada una?

	ISO/IEC 27001	ISO/IEC 27002
¿Qué es?	Norma de requisitos para un Sistema de Gestión de Seguridad de la Información (SGSI).	Catálogo de buenas prácticas y controles para implementar la seguridad.
Rol	Dice QUÉ hay que hacer (los requisitos del sistema de gestión).	Sugiere CÓMO hacerlo (lista de controles concretos).
¿Certificable?	Sí . Una empresa puede certificarse en 27001.	No por sí sola; acompaña a la 27001.
Analogía	Es como la “constitución” que define que debe existir un sistema de seguridad.	Es como el “manual de procedimientos” con controles puntuales.

La relación entre ambas

La **27001** establece que la organización debe gestionar sus riesgos de seguridad de forma sistemática (planificar, implementar, verificar, mejorar). La **27002** le da el catálogo de controles posibles (control de acceso, criptografía, seguridad física, gestión de incidentes, etc.) para que elija cuáles aplicar según su análisis de riesgos.

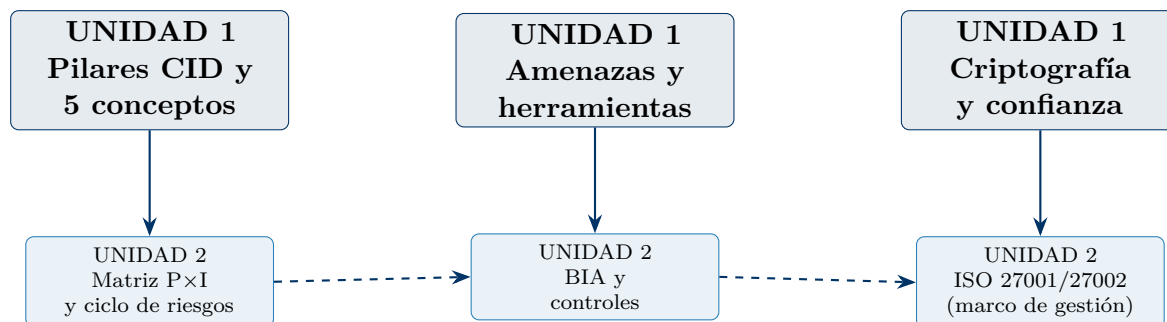
4.2 ¿Por qué le importa a un negocio digital?

- **Confianza comercial:** estar certificado (o alineado) a ISO 27001 es una señal fuerte para clientes y partners.
- **Orden interno:** da un marco para no “apagar incendios” sino gestionar la seguridad con método.
- **Ventaja competitiva:** muchas licitaciones y contratos B2B exigen cumplimiento de estándares de seguridad.

Para tu TP Integrador: no necesitás certificar ISO 27001 (eso es costoso y lleva meses). Pero **alinear** tu programa de seguridad con la lógica de la norma (identificar riesgos → elegir controles → documentar políticas → mejorar continuamente) le da rigor profesional a tu trabajo.

5. Cierre de Unidad 2: mapa integrador

Con esta clase cerramos la **Unidad 2: Gestión de Riesgos**. Así se conecta todo lo visto entre la Unidad 1 y la Unidad 2:



Lo que nos llevamos de la Unidad 2

- Aplicar el **ciclo de gestión de riesgos** (identificar, analizar, evaluar, tratar).
- Construir y leer una **matriz de probabilidad e impacto**.
- Cuantificar el daño con un **BIA** (MTD, RTO, RPO).
- Elegir **controles** con criterio **costo-beneficio**.
- Conocer el marco **ISO/IEC 27001/27002** como referencia profesional.

6. PARCIAL 1: formato, rúbrica y recomendaciones

Modalidad:	Grupal (mismos grupos del TP Integrador), en clase.
Duración:	70 minutos.
Cobertura:	Unidades 1 y 2.
Caso:	Un negocio digital nuevo , no visto antes en clase.
Nota:	1 a 10. Se aprueba con 4.

6.1 ¿Qué deben entregar?

Cada grupo recibe un caso nuevo y debe producir:

1. Una **matriz de riesgos** (identificar activos, amenazas, vulnerabilidades y ubicarlos en la matriz P×I).
2. Un **BIA simplificado** de los procesos críticos del caso.
3. **3 controles priorizados**, cada uno con su **justificación costo-beneficio**.

6.2 Rúbrica de evaluación (sobre 10 puntos)

¿Qué se evalúa?	Puntos
Identificación de activos y riesgos del caso	hasta 3
Correcta aplicación de la matriz de probabilidad e impacto	hasta 3
Pertinencia y justificación costo-beneficio de los controles propuestos	hasta 2
Comprensión individual demostrada en las preguntas cruzadas de cierre	hasta 2
TOTAL	10

6.3 Las preguntas cruzadas individuales

Al final, el docente hará preguntas individuales a cada integrante para verificar la comprensión **personal** dentro del trabajo grupal. Ejemplos de lo que pueden preguntarles:

- ¿Por qué ubicaste ese riesgo en “Alto” y no en “Medio”?
- ¿Qué diferencia hay entre el control que propusiste y uno preventivo?
- ¿Cómo justificás el costo-beneficio de ese control?
- Si el BIA dice que el proceso tolera 4 horas caído, ¿por qué propusiste un RTO de 8?

1. **Distribuyan roles rápido:** uno arma la matriz, otro el BIA, otro los controles, todos revisan.
2. **Lean el caso dos veces** antes de empezar; la mayoría de los errores vienen de no leer bien.
3. **Justifiquen todo:** un control sin costo-beneficio pierde puntos.
4. **Todos deben poder explicar** cualquier parte; las preguntas cruzadas son individuales.

7. Simulacro de Parcial: caso de práctica

Contexto: “TurnosYa” es un SaaS que gestiona turnos y fichas de pacientes para 50 clínicas. Tiene 8 empleados. Funciona 100 % en la nube.

Activos principales:

- Base de datos de pacientes (incluye datos sensibles de salud).
- Sistema de agenda de turnos en tiempo real.
- Pasarela de pago de consultas.
- Credenciales de acceso de los médicos.

Amenazas latentes: ransomware, caída del proveedor cloud, filtración de datos de salud, phishing a empleados.

Consigna del simulacro (hacelo en grupo, como si fuera el Parcial):

1. **Matriz de riesgos:** identificá al menos 3 riesgos del caso y ubicalos en la matriz $P \times I$.
2. **BIA simplificado:** para el “sistema de agenda de turnos” y la “base de datos de pacientes”, definí MTD, RTO, RPO y prioridad.
3. **3 controles priorizados:** proponelos con justificación costo-beneficio.

(1) Matriz de riesgos (3 riesgos con P, I y nivel):

(2) BIA simplificado (agenda de turnos + base de datos):

(3) 3 controles priorizados con costo-beneficio:

8. Glosario de la Clase 6

Término	Definición en una línea
BIA	Análisis de Impacto al Negocio; mide el daño de una interrupción.
MTD	Máximo tiempo tolerable de interrupción de un proceso.
RTO	Objetivo de tiempo de recuperación tras un incidente.
RPO	Pérdida máxima de datos aceptable (define frecuencia de backup).
Control	Medida para reducir la probabilidad o el impacto de un riesgo.
Control preventivo	Evita que el incidente ocurra.
Control detectivo	Alerta cuando el incidente está ocurriendo.
Control correctivo	Restaura la normalidad tras el incidente.
Costo-beneficio	Criterio para decidir si un control vale la pena.
ISO/IEC 27001	Norma de requisitos de un SGSI (certificable).
ISO/IEC 27002	Catálogo de buenas prácticas y controles.
SGSI	Sistema de Gestión de Seguridad de la Información.

9. Espacio para notas y dudas

Usá este espacio para dudas sobre el Parcial 1, ideas de controles, o conceptos de BIA e ISO que quieras repasar.